

Project Execution Notes

Project:

Enterprise Security Architecture Using JWS Authentication, FortiGate Security Controls, and Wireshark Traffic Analysis

Author:

Suhaib Kashif

Environment Startup Procedure

Step 1 - Start EVE-NG Lab

Power on the following devices:

- EDGE-RTR01
- FortiGate Firewall
- WEB-API-SRV01
- SOC-CLIENT01
- KALI-RED01

Verify connectivity using ping.

Web Application Startup

WEB-API-SRV01

Navigate to project directory:

```
cd ~/secure-jws-api
```

Start application:

```
node server.js
```

Expected Output:

HTTP Server running on port 3000

HTTPS Server running on port 3443

Verify:

curl <http://127.0.0.1:3000>

Authentication Test

SOC-CLIENT01

Open:

<http://10.10.10.10:3000>

Credentials:

Username: admin

Password: admin123

Click:

Login & Generate Token

Expected Result:

JWS token successfully generated.

Evidence:

SOC dashboard screenshot

Wireshark authentication capture

Authorization Test

Click:

Access Secure Data

Expected Result:

Protected resource returned.

Verify:

Authorization header present.

Evidence:

Authorization Wireshark capture.

Unauthorized Access Test

KALI-RED01

Command:

```
curl http://10.10.10.10:3000/secure-data
```

Expected:

Access denied.

Purpose:

Validate authorization enforcement.

Token Tampering Test

Modify valid token.

Command:

```
curl http://10.10.10.10:3000/secure-data  
-H "Authorization: Bearer MODIFIED_TOKEN"
```

Expected:

Invalid or Tampered Token

Purpose:

Validate JWS integrity protection.

Replay Attack Demonstration

Capture Authorization header using Wireshark.

Observe:

Authorization: Bearer eyJ...

Copy token.

Reuse token from another host.

Expected:

Access granted while token remains valid.

Purpose:

Demonstrate replay attack exposure when using HTTP.

SYN Flood Attack

KALI-RED01

Command:

```
sudo hping3 -S --flood -p 3000 10.10.10.10
```

Duration:

10–15 seconds

Purpose:

Simulate denial-of-service attack.

Evidence:

Kali screenshot

Wireshark capture

FortiGate logs

FortiGate Validation

Navigate:

Log & Report

→ Anomaly

Expected:

tcp_syn_flood

Verify:

Source IP

Destination IP

Action

Timestamp

Purpose:

Demonstrate attack detection and mitigation.

HTTPS Validation

Open:

<https://10.10.10.10:3443>

Accept certificate warning.

Perform login.

Start Wireshark.

Filter:

`tcp.port == 3443`

Observe:

TLS Handshake

Encrypted Application Data

Verify:

Credentials hidden

Token hidden

Purpose:

Validate confidentiality protection.

Final Verification Checklist

[✓] Authentication Works

[✓] Authorization Works

[✓] Unauthorized Access Blocked

[✓] Token Tampering Detected

[✓] Replay Attack Exposure Demonstrated

[✓] HTTPS Implemented

[✓] SYN Flood Generated

[✓] FortiGate Detection Verified

[✓] IPS Enabled

[✓] Network Segmentation Enforced

